

Badi

Enterprise Cyber GRC & Compliance Automation Platform

Audit Evidence Package

Riyadh Regulated Financial Enterprise

Assessment **Identity and Access Management Control Readiness Assessment**

Scope **Saudi cybersecurity baseline with metadata-only ISO/IEC 27001 mapping**

Generated at **2026-09-19 11:51**

Version **1.0**

Owner **Noura AlFahad**

Classification **Confidential**

Document control

Organization	Riyadh Regulated Financial Enterprise
Tenant	Riyadh Regulated Financial Enterprise
Sector	Financial Services
Assessment	Identity and Access Management Control Readiness Assessment (In review)
Document ID	838a2eec-0520-4c67-af67-cf4db5b9c118
Classification	Confidential
Version	1.0
Owner	Noura AlFahad
Generated at	2026-09-19 11:51
Controls in scope	6
Provenance & licensing	Generated draft • Internal • Human review required

LINKED FRAMEWORKS

CIS-CONTROLS 8.1 • DORA metadata-2026 • GDPR metadata-2026 • ISO-22301 metadata-2026 • ISO-31000 metadata-2026 • ISO-IEC-27001 2022 • ISO-IEC-27002 2022 • ISO-IEC-27005 metadata-2026 • ISO-IEC-27701 metadata-2026 • NCA-CCC metadata-2026 • NCA-DCC metadata-2026 • NCA-ECC 2-2024 • NIS2 metadata-2026 • NIST-CSF 2.0 • PCI-DSS 4.0.1 • SAMA-CSF metadata-2026 • SOC2 metadata-2026

Mandatory review notice

This is a generated draft evidence package. It is NOT a claim of full compliance or certification. It must be reviewed and approved by authorized compliance, legal, and cybersecurity personnel before operational use or submission as audit evidence.

This package reflects only the data the generating user is permitted to view; the absence of an item here does not imply it does not exist in the organization.

Readiness summary

AUDIT READINESS	TOTAL CONTROLS	OPEN HIGH GAPS	EVIDENCE UNDER REVIEW	NOT AUDIT-ELIGIBLE
Limited	6	1	2	6

Platform interface

Live captures of this tenant's own workspace; the figures shown in the interface match the records in this report.

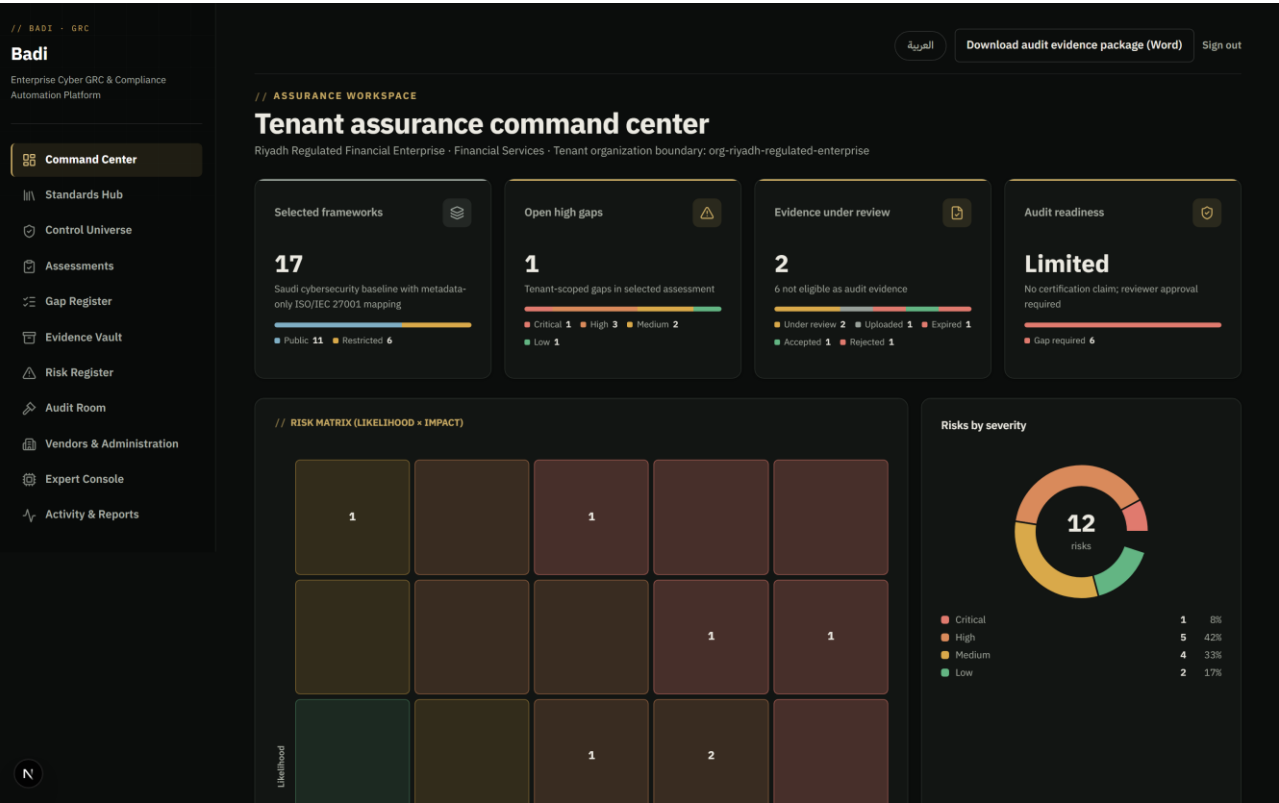


FIG 01 Tenant assurance command center

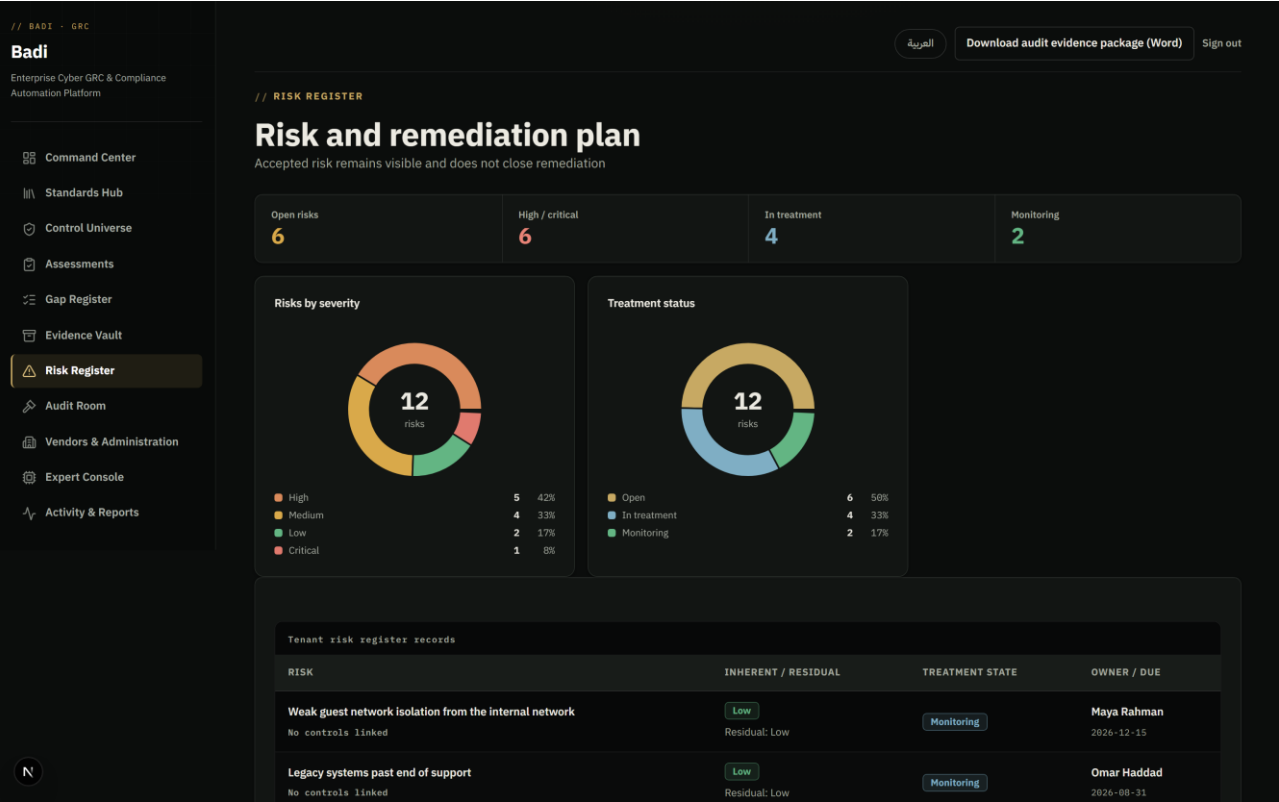


FIG 02 Risk register and treatment plan

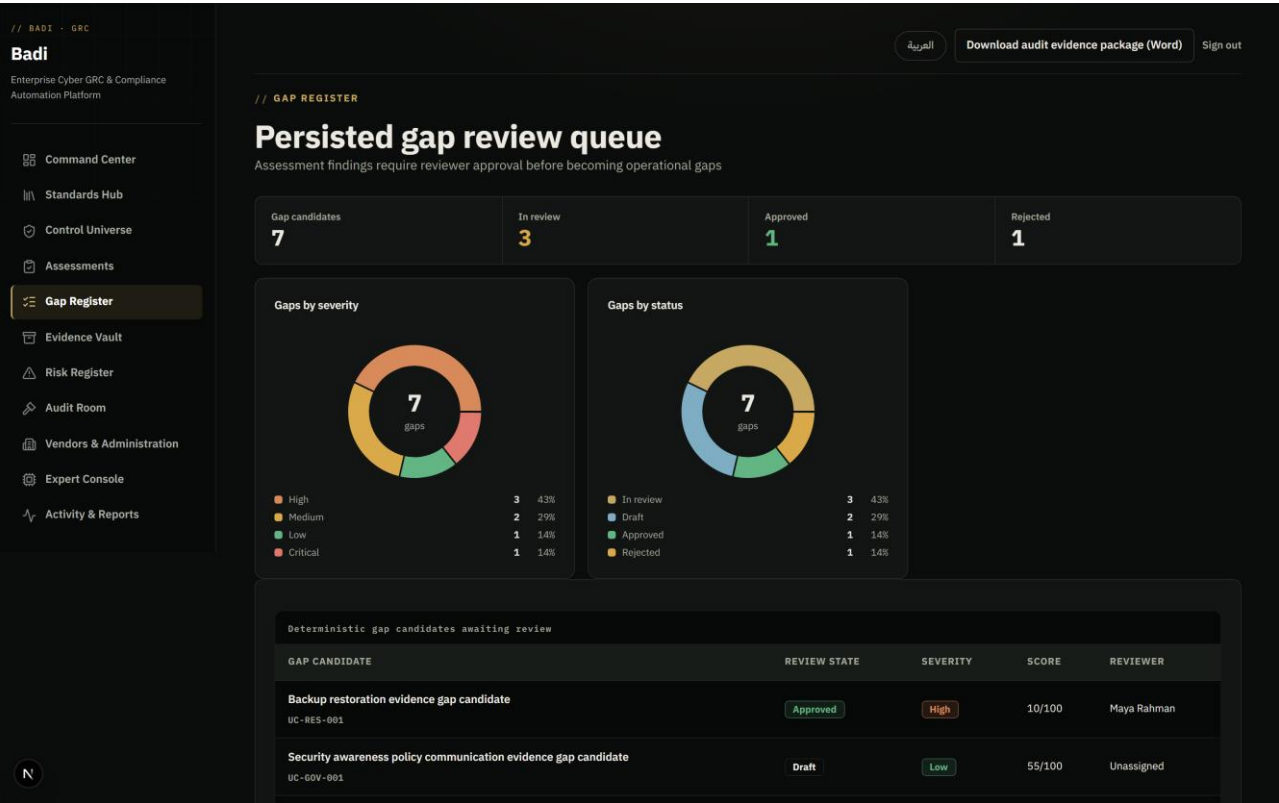


FIG 03 Persisted gap review queue

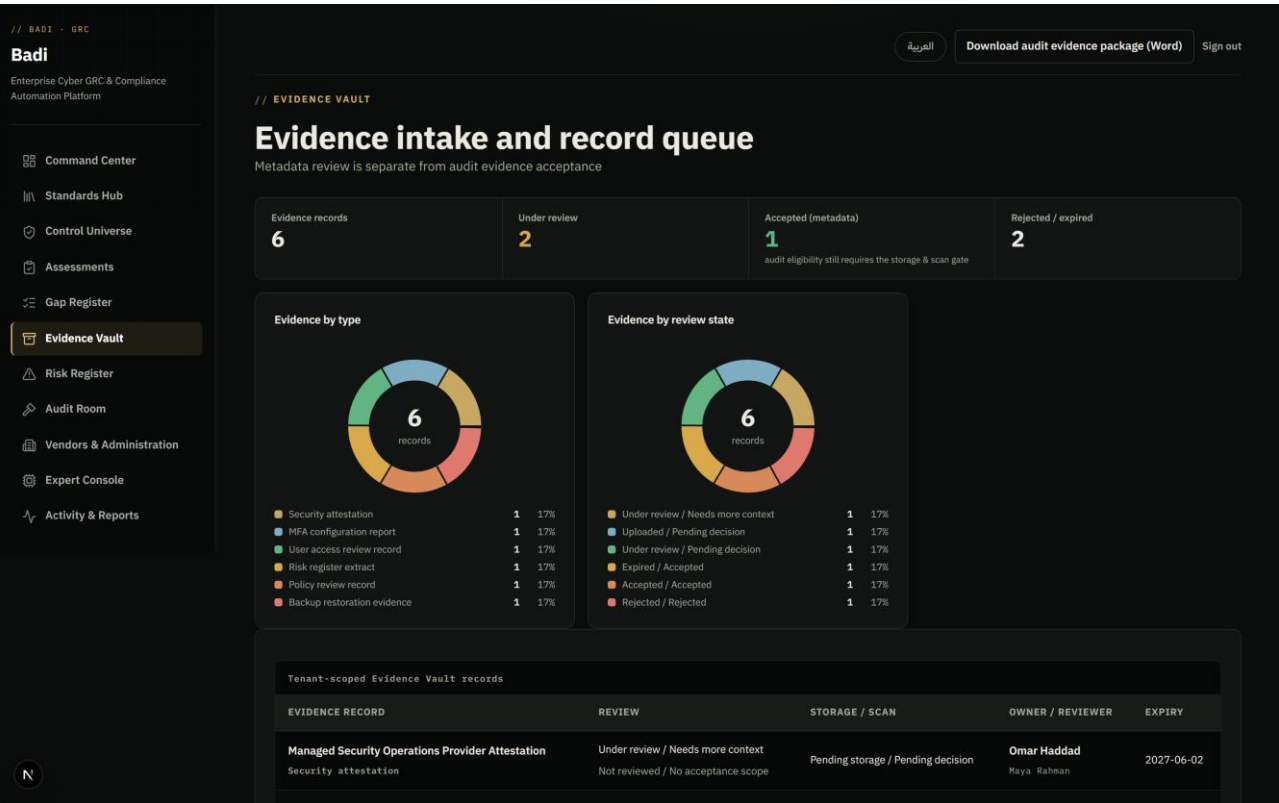


FIG 04 Evidence vault and intake gates

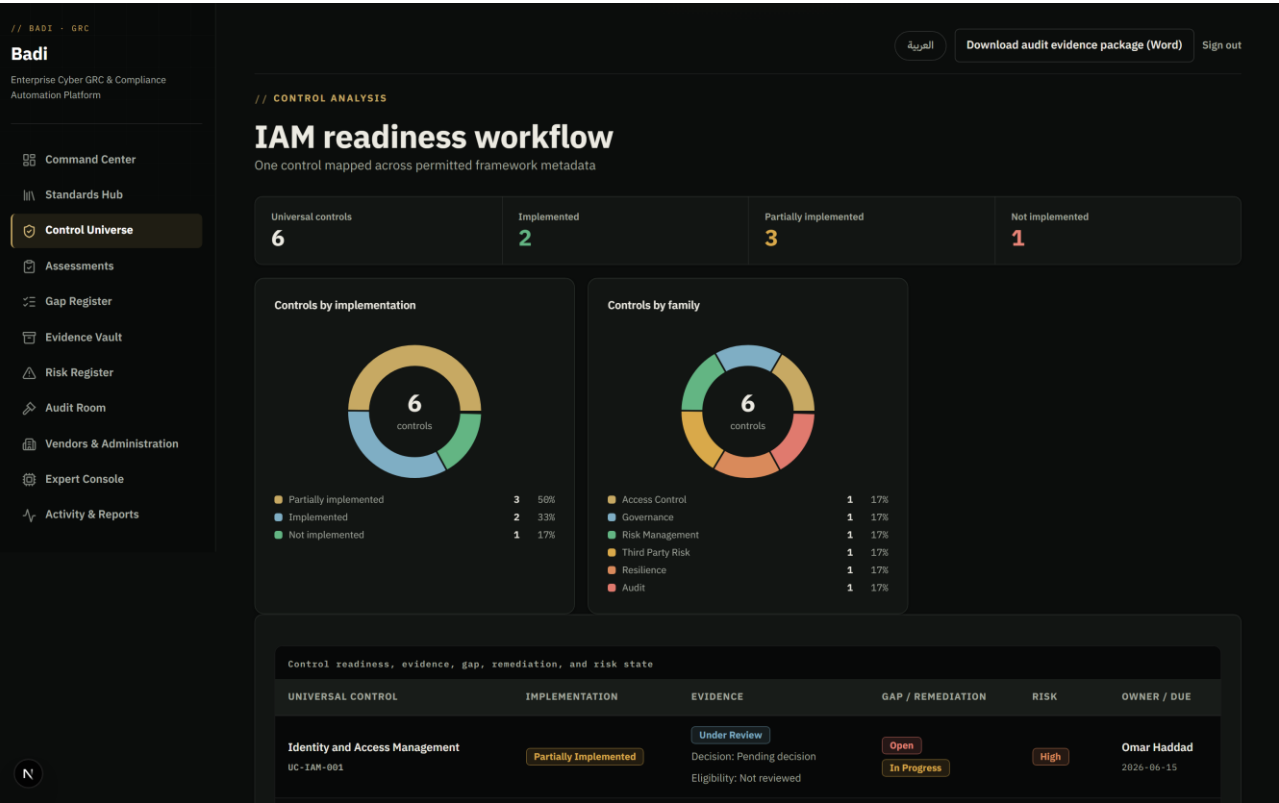


FIG 05 Universal control workspace

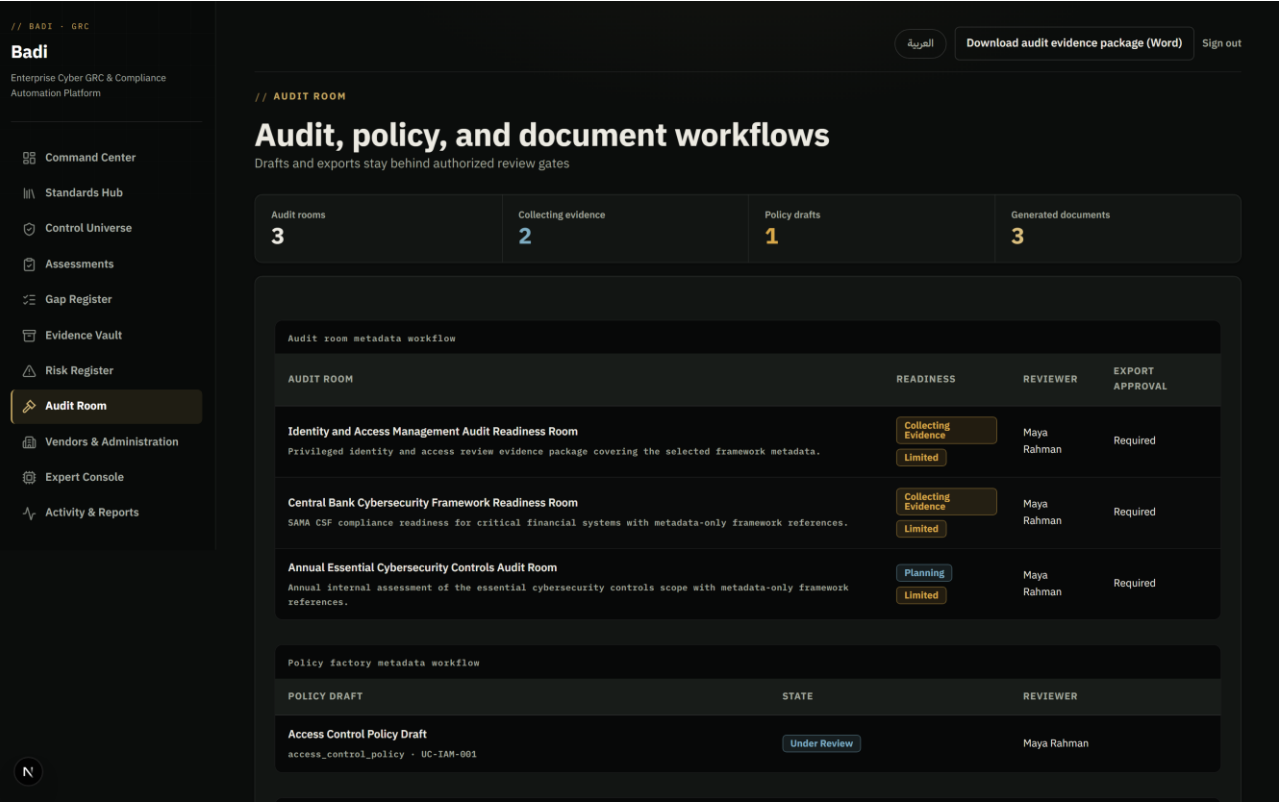


FIG 06 Audit room and document governance

// 05

Platform capabilities

Implemented, tested behavior in the platform today — not a roadmap and not marketing claims.

Tenant isolation by design Every query is scoped to the organization boundary server-side; joined records are re-filtered so no view can cross tenants.	Server-side role-based authorization Permissions are re-derived from database membership on every request; client-claimed roles are ignored and denials are audited.
Transactional audit trail Every create, update, approval, generation, and export writes its audit row inside the same database transaction as the change.	Deterministic assessment engine Control readiness, gap severity, and evidence sufficiency are computed by a tested, deterministic scoring engine — same inputs, same verdicts.
Fail-closed evidence gates Evidence is never audit-eligible until isolation, malware scanning, source grounding, and reviewer acceptance ALL pass.	License-aware standards hub Framework references are metadata-only where licensing requires; restricted standard text is never stored or reproduced.
Bilingual, Arabic-first interface Full Arabic RTL and English workspaces with one governed design system and localized status vocabulary end to end.	Governed document factory Audit evidence packages render as bilingual Word documents with mandatory human-review notices and permission-honest scope.

// 06

Analytics

RISKS BY SEVERITY



GAP CANDIDATES BY REVIEW STATE



EVIDENCE LIFECYCLE



RISK TREATMENT STATUS



// 07

Risk register

RISK MATRIX (LIKELIHOOD × IMPACT)

L \ I	1	2	3	4	5
5	1		1		
4				1	1
3			1	2	
2		1		1	1
1	1				1

Rows: likelihood 5 → 1 · Columns: impact 1 → 5 · Cell value = number of risks

RISK	L × I	LEVEL	RESIDUAL	STATUS	OWNER
Exfiltration of sensitive customer data	4×5	Critical	High	Open	Omar Haddad
Critical systems missing security patches	4×4	High	High	Open	Omar Haddad

RISK	L × I	LEVEL	RESIDUAL	STATUS	OWNER
Phishing campaigns targeting employees	5×3	High	Medium	In treatment	Omar Haddad
Concentration risk on a single cloud provider	3×4	Medium	Medium	Open	Omar Haddad
Excessive privileged access persists after role changes	3×4	High	Medium	Open	Omar Haddad
Insider misuse of privileged access	2×5	High	Medium	Open	Omar Haddad
Security configuration drift from the approved baseline	3×3	Medium	Low	In treatment	Omar Haddad
Backup restoration failure when recovery is required	2×4	Medium	Low	In treatment	Omar Haddad

// 08

Gap register

GAP	FRAMEWORK	STATE	LEVEL	SCORE	REVIEWER
Backup restoration evidence gap candidate	UC-RES-001	Approved	High	10/100	Maya Rahman
Security awareness policy communication evidence gap candidate	UC-GOV-001	Draft	Low	55/100	Not set
Joiner, mover, and leaver process gap candidate	UC-IAM-001	Draft	High	20/100	Not set
Mid-tier vendor assessment coverage gap candidate	UC-VRM-001	In review	Medium	35/100	Maya Rahman
Privileged session logging and monitoring gap candidate	UC-IAM-001	In review	Critical	5/100	Maya Rahman
Identity and access management readiness gap candidate	UC-IAM-001	In review	High	0/100	Maya Rahman
Cryptographic key management standard gap candidate	UC-GOV-001	Rejected	Medium	45/100	Maya Rahman

// 09

Evidence vault

TITLE	STATE	DECISION	STORAGE / SCAN	CLASSIFICATION	EXPIRY
Managed Security Operations Provider Attestation	Under review	Needs more context	pending storage / Pending decision	Internal	2027-06-02
Q2 Multi-Factor Authentication Configuration Report	Uploaded	Pending decision	pending storage / Pending decision	Confidential	2026-12-31
Q1 Privileged Access Review Record	Under review	Pending decision	pending storage / Pending decision	Confidential	2026-09-30
2025 Risk Register Extract	Expired	Accepted	pending storage / Pending decision	Internal	2026-03-31
Annual Cybersecurity Policy Review Record	Accepted	Accepted	pending storage / Pending decision	Internal	2027-05-10
H1 Backup Restoration Test Report	Rejected	Rejected	pending storage / Pending decision	Confidential	2026-11-30

// 10

Audit room & document governance

AUDIT ROOMS

TITLE	SCOPE	STATE	READINESS	REVIEWER
Identity and Access Management Audit Readiness Room	Privileged identity and access review evidence package covering the selected framework metadata.	Collecting evidence	Limited	Maya Rahman
Central Bank Cybersecurity Framework Readiness Room	SAMA CSF compliance readiness for critical financial systems with metadata-only framework references.	Collecting evidence	Limited	Maya Rahman
Annual Essential Cybersecurity Controls Audit Room	Annual internal assessment of the essential cybersecurity controls scope with metadata-only framework references.	Planning	Limited	Maya Rahman

POLICY DRAFTS

TITLE	POLICY TYPE	STATE	REVIEWER
Access Control Policy Draft	access control policy	Under review	Maya Rahman

GENERATED DOCUMENTS

TITLE	DOCUMENT TYPE	STATE	CLASSIFICATION	GENERATED	LANG
Audit Evidence Package	docx audit evidence package	Under review	Confidential	2026-09-19 11:43	AR
Audit Evidence Package	docx audit evidence package	Under review	Confidential	2026-09-19 11:45	EN
Audit Evidence Package	docx audit evidence package	Under review	Confidential	2026-09-19 11:43	EN
Audit Evidence Package	docx audit evidence package	Under review	Confidential	2026-09-19 11:45	AR
Access Control Policy Draft	docx policy	Under review	Internal	2026-09-19 08:50	—

// 11

Vendors & compliance calendar

VENDOR RISK REGISTER

ORGANIZATION	SERVICE CATEGORY	CRITICALITY	ASSESSMENT STATE	RESIDUAL RISK	OWNER
Datacenter Colocation Provider	Infrastructure hosting	Medium	Not started	Medium	Omar Haddad
Managed Security Operations Center Provider	Security monitoring services	High	Approved	Medium	Noura AlFahad
Cloud Identity Provider	Identity platform	Critical	In review	Medium	Omar Haddad

COMPLIANCE CALENDAR

TITLE	EVENT TYPE	STATE	DUE	OWNER
Quarterly Privileged Access Review	Control review	Due soon	2026-06-30	Omar Haddad
H2 Security Awareness Policy Communication	Policy review	Completed	2026-07-15	Omar Haddad
Quarterly Central Bank Cybersecurity Framework Compliance Report	Regulatory report	Due soon	2026-09-30	Noura AlFahad
Annual Essential Cybersecurity Controls Self-Assessment	Framework assessment	Scheduled	2026-10-15	Omar Haddad
Annual Managed Security Operations Provider Review	Vendor review	Scheduled	2026-10-31	Noura AlFahad

TITLE	EVENT TYPE	STATE	DUE	OWNER
Annual Business Continuity and Recovery Exercise	Resilience exercise	Scheduled	2026-11-15	Omar Haddad

// 12

Platform module registry

MODULE	STATE	OWNER ROLE	RECORDS	NEXT ACTION
Standards Hub	Active	grc manager	17	Review metadata packs and import provenance.
Assessment Studio	Active	grc manager	7	Convert deterministic findings into reviewed gap decisions.
Gap Register	Active	grc manager	7	Approve or reject draft gap candidates.
Risk Register	Active	grc manager	12	Confirm treatment state and residual risk.
Remediation Planner	Active	control owner	1	Complete due tasks and refresh evidence links.
Evidence Vault	Active	evidence reviewer	6	Keep metadata review separate from audit evidence acceptance.
Audit Room	Active	auditor	3	Prepare evidence packages behind export approval gates.
Policy Factory	Active	grc manager	1	Route generated drafts through authorized review.
Document Factory	Active	grc manager	5	Maintain document metadata and approval state.
Vendor Risk	Active	grc manager	3	Review critical vendors and linked framework evidence.
Compliance Calendar	Active	control owner	6	Track review due dates and regulator-facing milestones.
Administration	Active	tenant admin	3	Review tenant memberships, roles, and least privilege.
Executive Dashboard	Active	executive viewer	16	Monitor risk, remediation, and audit readiness trends.

// 13

Frameworks in scope

FRAMEWORK	VERSION	JURISDICTION	LICENSE	USAGE POLICY
CIS-CONTROLS	8.1	Global	Public	Human review required
DORA	metadata-2026	European Union	Public	Human review required
GDPR	metadata-2026	European Union	Public	Human review required
ISO-22301	metadata-2026	International	Restricted	Metadata only
ISO-31000	metadata-2026	International	Restricted	Metadata only
ISO-IEC-27001	2022	International	Restricted	Metadata only
ISO-IEC-27002	2022	International	Restricted	Metadata only
ISO-IEC-27005	metadata-2026	International	Restricted	Metadata only
ISO-IEC-27701	metadata-2026	International	Restricted	Metadata only
NCA-CCC	metadata-2026	Saudi Arabia	Public	Human review required
NCA-DCC	metadata-2026	Saudi Arabia	Public	Human review required
NCA-ECC	2-2024	Saudi Arabia	Public	Human review required
NIS2	metadata-2026	European Union	Public	Human review required
NIST-CSF	2.0	United States	Public	Human review required

FRAMEWORK	VERSION	JURISDICTION	LICENSE	USAGE POLICY
PCI-DSS	4.0.1	Global	Public	Human review required
SAMA-CSF	metadata-2026	Saudi Arabia	Public	Human review required
SOC2	metadata-2026	United States	Public	Human review required

// 14

Annex A — Controls and evidence detail

UC-IAM-001 Identity and Access Management

Family: **Access Control** Implementation: **Partially implemented**

FRAMEWORK MAPPINGS

FRAMEWORK	REFERENCE	CONFIDENCE
NCA-ECC 2-2024	NCA-ECC-IAM-META	Strong
ISO-IEC-27001 2022	ISO27001-IAM-META	Manual review required

EVIDENCE

TITLE	STATE	DECISION	AUDIT ELIGIBILITY	CLASSIFICATION
Q1 Privileged Access Review Record	Under review	Pending decision	Not eligible as audit evidence	Confidential
Q2 Multi-Factor Authentication Configuration Report	Uploaded	Pending decision	Not eligible as audit evidence	Confidential

Gap Privileged access review evidence lacks approval · Status: **Open** · Level: **High**

Remediation Approve privileged access review evidence · Status: **In progress** · Priority: **High**

Risk Excessive privileged access persists after role changes · Level: **High** · Residual: **Medium**

UC-GOV-001 Cybersecurity Policy Governance

Family: **Governance** Implementation: **Implemented**

FRAMEWORK MAPPINGS

FRAMEWORK	REFERENCE	CONFIDENCE
NIST-CSF 2.0	NIST-CSF-FOUNDATION-META	Partial
CIS-CONTROLS 8.1	CIS-CONTROLS-FOUNDATION-META	Partial
SOC2 metadata-2026	SOC2-FOUNDATION-META	Partial
PCI-DSS 4.0.1	PCI-DSS-FOUNDATION-META	Partial
ISO-IEC-27002 2022	ISO-IEC-27002-FOUNDATION-META	Manual review required
ISO-IEC-27701 metadata-2026	ISO-IEC-27701-FOUNDATION-META	Manual review required

EVIDENCE

TITLE	STATE	DECISION	AUDIT ELIGIBILITY	CLASSIFICATION
Annual Cybersecurity Policy Review Record	Accepted	Accepted	Not eligible as audit evidence	Internal

UC-RISK-001 Enterprise Cyber Risk Management

Family: **Risk Management** Implementation: **Implemented**

FRAMEWORK MAPPINGS

FRAMEWORK	REFERENCE	CONFIDENCE
NCA-DCC metadata-2026	NCA-DCC-FOUNDATION-META	Partial
SAMA-CSF metadata-2026	SAMA-CSF-FOUNDATION-META	Partial
GDPR metadata-2026	GDPR-FOUNDATION-META	Partial
DORA metadata-2026	DORA-FOUNDATION-META	Partial
NIS2 metadata-2026	NIS2-FOUNDATION-META	Partial
ISO-IEC-27005 metadata-2026	ISO-IEC-27005-FOUNDATION-META	Manual review required
ISO-31000 metadata-2026	ISO-31000-FOUNDATION-META	Manual review required
NCA-CCC metadata-2026	NCA-CCC-FOUNDATION-META	Partial

EVIDENCE

TITLE	STATE	DECISION	AUDIT ELIGIBILITY	CLASSIFICATION
2025 Risk Register Extract	Expired	Accepted	Not eligible as audit evidence	Internal

UC-VRM-001 Vendor Security Risk Management

Family: Third Party Risk Implementation: Partially implemented

EVIDENCE

TITLE	STATE	DECISION	AUDIT ELIGIBILITY	CLASSIFICATION
Managed Security Operations Provider Attestation	Under review	Needs more context	Not eligible as audit evidence	Internal

Risk Prolonged regional datacenter outage Level: High Residual: Medium

UC-RES-001 Resilience and Continuity Planning

Family: Resilience Implementation: Partially implemented

FRAMEWORK MAPPINGS

FRAMEWORK	REFERENCE	CONFIDENCE
ISO-22301 metadata-2026	ISO-22301-FOUNDATION-META	Manual review required

EVIDENCE

TITLE	STATE	DECISION	AUDIT ELIGIBILITY	CLASSIFICATION
H1 Backup Restoration Test Report	Rejected	Rejected	Not eligible as audit evidence	Confidential

Gap Backup restoration test evidence is incomplete Status: In progress Level: High

Risk Prolonged regional datacenter outage Level: High Residual: Medium

UC-AUD-001 Audit Readiness Management

Family: Audit Implementation: Not implemented

EVIDENCE

No linked evidence yet.